Category: Defensive cybersecurity and payment-brand abuse investigation

Report date: 25 October 2026

Status: Working development/demo system; not a production banking service

UPI Shield Project Report

Project: UPI Shield **Category:** Defensive cybersecurity and payment-brand abuse investigation **Report date:** 25 October 2026 **Status:** Working development/demo system; not a production banking service

1. Executive summary

UPI Shield is a web-based investigation tool for cybersecurity analysts. It helps them examine websites and screenshots that may imitate UPI, banking, or other payment brands. It combines visual, page-content, URL, and authorized network signals into a risk assessment, saves findings and evidence, and presents them in an analyst dashboard and campaign graph.

The tool is intended to support investigation and prioritization. Its automated verdicts are indicators for human review, not proof that a website is malicious. UPI Shield is not a UPI payment app, does not connect to bank accounts, and cannot block, reverse, or protect a real payment.

2. Problem statement

Fraudulent payment-themed pages can imitate trusted brands and use misleading URLs or page behavior to persuade people to disclose information. Analysts need a repeatable way to inspect suspected pages, keep the supporting evidence, and compare related infrastructure and findings.

UPI Shield addresses this investigation workflow by bringing authorized collection, multi-signal analysis, evidence storage, and review into one workspace.

3. Objectives

- Provide a controlled workspace for investigating suspected payment-brand

abuse.

- Analyze an authorized URL or an uploaded screenshot.
- Explain risk findings through multiple signals rather than a single URL rule.
- Store findings and supporting evidence for later review.
- Help analysts compare related domains and infrastructure.
- Provide account, activity, and aggregate usage information to authorized

administrators.

- Keep potentially active website collection restricted to an explicit

allowlist.

4. Intended users

Primary users

- Cybersecurity analysts and digital-fraud investigation teams.

- Security operations or trust-and-safety teams reviewing suspicious pages.
- Authorized researchers investigating payment-brand impersonation.

Secondary users

- Students and security testers learning about defensive website analysis in a

local or otherwise authorized environment.

The system is not designed for everyday consumers to make UPI payments or as a replacement for a bank's fraud-reporting and account-protection services.

5. Scope

Included

- Analyst account registration, email verification, sign-in, and sign-out.
- Email notifications for account confirmation and successful sign-in.
- Dashboard for detections, verdict counts, risk activity, and service status.
- Authorized website capture and analysis.
- Screenshot upload analysis without connecting to the submitted website.
- Detection detail and evidence review, including PDF report generation.
- Discovery queue ingestion for analyst-supplied URLs.
- Graph views for infrastructure observations and related campaigns.
- Administrator views for account, login, aggregate visit, and activity metrics.
- Health reporting for the API and supporting services.

Not included

- Processing UPI payments or connecting to a bank, wallet, or payment network.
- Automatically blocking websites, freezing accounts, or recovering money.
- A guarantee that an automated classification is correct.
- Unrestricted public crawling or scanning of arbitrary third-party targets.
- Production-grade public hosting or a permanent public domain in the current

temporary demo configuration.

6. Main user workflows

6.1 Create and verify an account

1. The user enters a name, email, country-coded mobile number, and password.
2. The service stores the account and sends a confirmation link using its

configured SMTP provider.

3. The user opens the link and confirms the email address.
4. The user can then sign in. A sign-in notification is sent by email.

6.2 Investigate an authorized website

1. An analyst submits a URL that is within the configured crawl allowlist.
2. The service captures page evidence, such as a screenshot and DOM, and

collects permitted URL, DNS, TLS, or registration-related signals.

3. Visual, lexical, and behavioral signals contribute to a risk assessment.
4. The finding and evidence are saved for review.
5. The analyst reviews the result in the dashboard, detail view, or graph and

can generate a PDF evidence report.

6.3 Analyze an uploaded screenshot

1. An analyst uploads a screenshot and supplies its associated URL as context.
2. The system performs screenshot-oriented and lexical analysis.
3. It does not actively connect to the submitted host for this screenshot-only

workflow.

4. The resulting assessment can be reviewed alongside other detections.

6.4 Administrator review

An allowlisted administrator can review account totals, login information, aggregate page-view routes, activity events, and stored results through the admin dashboard and API.

7. Features and benefits

Feature	What it does	Benefit to users
Account verification	Confirms an email before account sign-in	Provides an account activation step
Secure sessions	Uses an HttpOnly session cookie with a seven-day lifetime	Keeps session tokens out of ordinary page scripts
Website capture	Collects evidence from allowlisted targets	Gives analysts a repeatable inspection workflow
Screenshot analysis	Evaluates an uploaded image without visiting its host	Supports offline or safer evidence review
Multi-signal assessment	Combines visual, DOM/behavioral, URL, and permitted network signals	Gives more context than a single indicator
Detection dashboard	Shows observations, verdict counts, activity, and service state	Helps analysts prioritize and track review
Evidence detail and PDF	Preserves and presents findings and supporting evidence	Makes investigation results easier to review and share
Campaign graph	Projects relationships among observations and infrastructure	Helps explore possible connections between findings
Admin dashboard	Shows account, activity, and aggregate usage information	Helps authorized owners monitor workspace use
Health endpoint	Reports database and graph-service availability	Makes service status easier to diagnose

8. System architecture and technologies

Frontend

- Next.js 16 and React 18.
- TypeScript for application code.
- D3 for graph visualization.
- Provides account screens, analyst dashboard, result views, graph, and admin UI.

Backend

- FastAPI provides the HTTP API.
- Pydantic validates incoming request data.
- SQLAlchemy provides database access.
- Playwright supports browser-based capture in the authorized capture workflow.
- ReportLab generates PDF evidence reports.

Data and supporting services

- **PostgreSQL 16:** accounts, sessions, activity, detections, and related

application records.

- **Neo4j 5:** graph observations and infrastructure relationships.
- **Redis 7:** cache/queue infrastructure; a Celery scaffold is present.
- **Mailpit:** local development email catcher.
- **Brevo SMTP:** configured external email transport when valid provider

credentials and an authorized sender are present.

High-level data flow

```
Analyst browser
      |
      +--> Next.js frontend
                |
                +--> FastAPI API
                        |
                        +--> Input validation and authorization
                        +--> Capture / screenshot analysis
                        +--> Risk signals and verdict
                        +--> PostgreSQL records and evidence
                        +--> Neo4j graph observations
                        +--> SMTP email and PDF reporting
```

9. Detection approach

The project documents a multi-signal pipeline that may combine:

- Visual similarity, including perceptual image hashing.
- Optical character recognition when the optional OCR dependency is available.
- DOM and page-behavior indicators.
- URL and lexical indicators.
- DNS, TLS certificate, and RDAP-related context when the target is authorized

by the allowlist.

The assessment is stored with its verdict, score, and supporting information. The exact signals available can depend on the target, configuration, and optional dependencies. Results should be treated as triage guidance and checked by a human analyst.

10. Data and privacy

- Passwords are stored as scrypt hashes, not plaintext.
- Browser sessions use HttpOnly cookies; the application stores a hash of the

session token on the server.

- Page-view analytics store aggregate route counts and do not persist visitor

IP addresses, cookies, or unique visitor identifiers through that route.

- Registration and investigation activity are recorded for administrative review.
- Detection URLs and their associated captured evidence can be stored in the database or evidence storage to support later investigation.
- Activity events use a configurable retention period (`ACTIVITY_RETENTION_DAYS`, 180 days by default).
- The activity cleanup does not automatically delete accounts, detection records, screenshots, or evidence files. Those require a separate retention policy.
- Email credentials belong in the ignored local `.env` file or deployment secrets; they must not be committed or shared.

11. Security and responsible use

- Active crawling and DNS/TLS/RDAP enrichment are restricted by `CRAWL_ALLOWLIST`, which defaults to localhost and `127.0.0.1`.
- Screenshot-only analysis does not actively connect to the submitted URL.
- Captured HTML evidence is served as a download rather than executable page content.
- Admin endpoints require an authenticated, allowlisted admin account.
- Public deployment should use HTTPS, exact frontend origins, strong secrets, a separate production database, appropriate email credentials, and an organization or invitation policy before opening registration to the public.
- The temporary public demo tunnel is not an uptime-guaranteed production deployment. It exposes the running development application to anyone with its current link while the tunnel is active.
- Only investigate URLs and systems for which the operator has authorization.

12. Database and administration

The database stores user profiles, verification tokens, sessions, activity events, detection records, and related evidence information. The admin APIs provide overview counts, account/login records, activity events, and stored results to allowlisted administrators.

The dashboard's **Observations** count refers to detection records, not users or website visitors. **High risk** counts findings classified as phishing, and **Needs review** counts suspicious verdicts. These are automated classifications, not confirmed incident counts.

At the time this report was prepared, the development database contained 12 detection records: 9 phishing and 3 benign. The examined sample URLs used `127.0.0.1`, indicating local/demo test data. These figures are a development snapshot, not real-world threat statistics.

13. Validation and current status

Previously completed checks include:

- Backend unit and route tests, including registration, verification, login, admin access, health, and email-failure behavior.

- Frontend TypeScript checking and production build.
- Python compilation and Compose configuration validation.
- Browser/API testing of registration, confirmation, and sign-in using a local test database and local mail catcher.
- PostgreSQL and Neo4j startup and health checks.
- Brevo SMTP authentication and acceptance of a test email.
- Regression tests for secure cross-origin session cookies when the API is behind the temporary HTTPS tunnel.

The most recent focused authentication test run passed 18 tests. The temporary public frontend and API tunnels were also responding successfully during setup. Those tunnels may stop or change and are not a stable deployment.

14. Known limitations and future improvements

Known limitations

- Automated verdicts can be false positives or false negatives and require analyst review.
- Some analysis signals depend on optional packages and external network lookups.
- Public demo tunnels have no production uptime guarantee and use development services on the host computer.
- No separate retention/cleanup policy is currently applied to stored evidence and detection records.
- The project is not a payment processor or consumer payment-protection app.

Recommended next steps

1. Deploy the frontend and API to a managed HTTPS hosting environment with a stable domain.
2. Use managed PostgreSQL and configure backups, migrations, monitoring, and access controls.
3. Keep SMTP and database credentials in the hosting provider's secret store.
4. Add invitation or organization-based registration before public launch.
5. Define retention and deletion policies for account and evidence data.
6. Add rate limits, abuse monitoring, operational alerts, and incident response procedures.
7. Evaluate detection quality using a documented, representative, labeled dataset and report precision, recall, F1, and false-positive rate with dataset limitations.
8. Conduct an independent security and privacy review before production use.

15. Conclusion

UPI Shield provides an analyst-focused workflow for collecting and reviewing evidence about potentially fraudulent payment-brand websites. Its main value is to organize multi-signal analysis and investigation records in one workspace. It can help analysts decide what to review first, but it does not replace human judgment, official reporting channels, or production security review.

Appendix A: Main API groups

API group	Representative routes
Authentication	`/auth/register`, `/auth/verify`, `/auth/resend-verification`, `/auth/login`, `/auth/me`, `/auth/logout`
Dashboard and health	`/health`, `/detections`, `/evaluation`
Capture and analysis	`/captures`, `/analyze-upload`, `/discover`, `/apps/inspect`
Investigation and reporting	`/detections/{id}`, `/detections/{id}/report`, `/graph`, `/graph/clusters`
Administration	`/admin/overview`, `/admin/users`, `/admin/activity`